Análisis de vulnerabilidades: Buen Fin

Santiago Martin Vences	A01787450
Ilan Hanenberg Wasserman	A01787440
Aixa Elenka Mendoza Filisola	A01782727
Nicolas Amaya Sarmiento	A01787217

Integración de seguridad informática en redes y sistemas de software

Grupo 422

Fecha:

19 de Septiembre del 2026

Introducción

Este documento tiene el objetivo de especificar las vulnerabilidades existentes en la versión actual de la aplicación del Buen Fin producida para la Secretaría de Economía. Para hacer este reporte se hizo uso de ZAP, una herramienta para escanear vulnerabilidades de código abierto.

Reporte de ZAP

https://drive.google.com/drive/folders/12GgjQfsrxKdyZUFCorJo6pBB34kqnvLp?usp=sharing

Vulnerabilidades encontradas

Cabecera Content Security Policy (CSP) no configurada

- Descripción: Indica que este tipo de cabecera está ausente de la respuesta de un endpoint. Esta cabecera sirve para que el navegador sepa que tiene que poner restricciones ante las cosas que el código del sitio puede hacer.
- Referencia: https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
- Recomendaciones: Declarar esta cabecera en todos los endpoints de la aplicación o declararla en nginx o apache y configurarla correctamente para reducir la posibilidad de ataques de XSS (Cross site scripting). Además, añadir pruebas a la pipeline de integración continúa para revisar que esta cabecera este presente en endpoints nuevos o editados.

Falta de cabecera Anti-Clickjacking (X-Frame-Options header)

- Descripción: Se refiere a la falta de una cabecera que sirve para definir si el contenido de la página web se puede renderizar en un iframe/frame. Esto es importante, ya que

un atacante puede sobreponer una página maliciosa sobre la página web para poder atacar a las personas que la usen.

- Referencia: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
- Recomendaciones: Declarar esta cabecera en todos los endpoints de la aplicación o declararla en nginx o apache y configurarla correctamente para reducir la posibilidad de ataques que intenten utilizar websites maliciosos utilizando la página web del buen fin como señuelo.

Strict-Transport-Security Header No Establecido

- Descripción: Se refiere a la falta de una cabecera que sirve para evitar y redirigir las peticiones HTTP a HTTPS para nuestra página web. Esto es importante, ya que aunque con declarar el certificado y especificar que el servidor haga uso de https se pueden traducir las peticiones https a https, si no declaramos esta cabecera las peticiones https se van a mandar por http y luego traducirse a https en el servidor. Al declarar esta cabecera, aunque una vez se haga la petición http desde el cliente, el resto de veces el navegador recordará que debe hacer la petición a través de https, evitando que nuestros clientes puedan ser atacados.
- Referencia: https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
- Recomendaciones: Declarar esta cabecera en todos los endpoints de la aplicación o declararla en nginx o apache y configurarla correctamente para reducir la posibilidad de ataques a clientes que por alguna razón hagan peticiones por http.

Falta encabezado X-Content-Type-Options

- Descripción: Se refiere a la falta de una encabezado que sirve para rechazar respuestas con MIME types (tipos mandados para ciertos tipos de archivo en el navegador) en elementos script y de hojas de estilos. Sirve para prevenir ataques que hagan uso de la confusión del MIME type.
- Referencia: https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
- Recomendaciones: Configurar el servidor para que incluya la cabecera en sus respuestas.

Detalles

Cabe resaltar que ZAP marcó que la aplicación divulgaba información que podría ser sensible y que recuperar cosas de una Caché. Además, ZAP también indica que se deberían reexaminar las directivas de control de caché. Sin embargo, las partes que se divulgan de información, que se pueden recuperar en caché y que hacen que la herramienta marqué la re examinación de directivas de control refieren a archivos y campos que son públicos, por lo cuál no hay peligro en estos sentidos realmente.

Conclusión

Se recomienda configurar las cabeceras de manera apropiada en la configuración de nginx, ya que aunque no son de un riesgo muy alto, si vale la pena resolver ese tipo de problemas en el desarrollo posterior. Además, se recomienda monitorear por posibles CVE's que puedan aparecer en un futuro. Finalmente, en el logger se recomienda añadir logging por dirección ip para mejorar la trazabilidad del sistema.